

# Hybrid Insider Threat Detection for Smart Building Operations Using Multi-Agent Simulation and Layered SIEM Correlation

Firdous Kausar <sup>1</sup>, Asmah Muallem <sup>1</sup>, Naw Safrin Sattar <sup>1</sup>, and Mohamed Zakaria Kurdi<sup>1</sup>

<sup>1</sup> Department of Computer Science and Data Science, SACS, Meharry Medical College, Nashville, USA; firdous.kausar@mmc.edu, asmah.muallem@mmc.edu, nawsafrin.sattar@mmc.edu, mohamed.kurdi@mmc.edu

\* Correspondence: firdous.kausar@mmc.edu;

## Abstract

We present a hybrid framework for adaptive insider-threat detection that tightly integrates multi-agent simulation (MAS), layered Security Information and Event Management (SIEM) correlation, behavioral and communication forensics, trust-aware machine learning, and Theory-of-Mind (ToM) reasoning. Intelligent agents operate in a simulated smart-building facilities environment, generating both behavioral events and cognitive intent signals that are ingested by a centralized SIEM. Email is modeled as an operational coordination and social-engineering channel correlated with control-plane actions. We evaluate four system variants: a Layered SIEM-Core (LSC) baseline, a Cognitive-Enriched SIEM (CE-SIEM) incorporating ToM and communication forensics, an Evidence-Gated SIEM (EG-SIEM) introducing precision-focused validation mechanisms, and an Enron-enabled EG-SIEM (EG-SIEM-Enron) that augments evidence gating with a pretrained email forensics module calibrated on Enron corpora. Across ten simulation runs involving eight malicious insiders, CE-SIEM achieves perfect recall (1.000) and improves actor-level F1 from 0.521 (LSC) to 0.774. EG-SIEM raises actor-level F1 to 0.922 and confirmed-alert precision to 0.997 while reducing false positives to 0.2 per run. EG-SIEM-Enron preserves high precision (1.000 confirmed-alert precision; 0.0 false positives per run), slightly improves actor-level F1 to 0.933, and reduces detection latency (average TTD 10.26 steps versus 15.20 for EG-SIEM). These results demonstrate that cognitive context improves sensitivity, evidence-gated validation enables high-precision, low-noise detection, and pretrained communication calibration can further accelerate high-confidence insider threat identification.

**Keywords:** Insider Threat Detection; Multi-Agent Systems; SIEM Correlation; Behavioral and Communication Forensics; Text Mining, Trust-Aware Anomaly Detection; Theory of Mind

## 1. Introduction

Insider threats are malicious or negligent actions by authorized users that pose severe challenges to organizational security. Unlike external attacks, insiders have legitimate access, making anomalous behavior hard to distinguish. Traditional detection e.g., static signatures or one-shot ML models often yield high false positives or fail under noise. Recent work has explored machine learning and anomaly-based SIEMs, but these alone neglect human factors like intent, trust, and communication context. To address this, we propose a hybrid system that bridges agent-based reasoning, behavioral analytics, and adaptive learning. Our approach builds a synthetic MAS environment of users (benign and

Received:

Revised:

Accepted:

Published:

**Copyright:** © 2026 by the authors.

Submitted to *Journal Not Specified* for possible open access publication under the terms and conditions of the

[Creative Commons Attribution \(CC BY\)](#) license.

various attacker types) interacting over resources and messaging. A central SIEM ingests the user logs and provides successive layers of analysis. Crucially, we augment agents with a Theory-of-Mind (ToM) layer to infer intentions, and we apply behavioral forensics on communications. An online learning component continuously updates feature weights, while trust calibration adjusts alert thresholds for each user.

Smart building and facilities management environments exacerbate these difficulties since municipal services depend on tightly integrated cyber-physical systems, for example, building management systems, access control, and safety monitoring. This is achieved on a control plane of remote sessions, configuration writes, and schedule or plan activations. The difficulty for defenders is to reason over various telemetry, including IT and facilities operations, for a city's Security Operations Center (SOC). This includes authentication activities, for instance, SSO and VPN, endpoint and file access, role and privilege activities, and building management system control plane logs. Simultaneously, day-to-day facilities activities require coordination of workflow communications, for instance, using email and ticket systems, to request changes, approve vendor activities, distribute configuration items, and request remote support. This implies that, though email is not a control channel for building actuators, it is a high-value evidence flow and an attack enabler flow, which can be utilized prior to, during, and after activities affecting cyber-physical systems, for instance, social engineering to obtain credentials and access, disclosure of sensitive facility documentation, and malicious change requests. This creates a wide insider surface and a tremendous "atypical-but-benign" volume, making false positives costly and false negatives costly in terms of operational impact.

### *1.1. Smart Building Operational Context and Threat Model*

Our focus is on smart buildings and facilities management infrastructures, where municipal services are delivered based on the integration of IT and OT, and cyber-physical systems (CPS). The assets we are concerned with include the building management systems (BMS) that control HVAC schedules and set points, ventilation and lighting schedules, access control systems, and facility networks that connect controllers and gateways. The operations in the facilities involve sensitive assets, such as floor plans, device lists, backups of controller configurations, and vendor maintenance materials, and remote access is often provided to third-party vendors for installation, diagnostics, and emergency support.

In this paper, an insider is described as a legitimate user (or a compromised account that is indistinguishable from a legitimate user at the log level) that has access to legitimate resources and communication channels. The defender is the municipal Security Operations Center (SOC) that monitors heterogeneous telemetry from both IT and facilities operations domains, including authentication events (SSO/VPN), endpoint/file access events, role/privilege changes, BMS control plane events (such as schedule/setpoint updates, configuration writes, controller overrides, alarm acknowledgements), as well as communication metadata/content events (email). Email is not used as a control channel for building actuators. Actuation is performed through the BMS control plane using remote sessions, configuration writes, and setpoint or schedule activations. Email is used as a workflow coordination and social engineering mechanism that can occur before or concurrently with control plane actions. Hence, email-based forensics is related to authentication, privileges, file access, and BMS control plane actions.

Table 1 identifies the five analyzed scenarios related to insiders, along with the smart buildings' operational equivalent, assets that are affected, and the main sources of evidence that are available to a municipal SOC/SIEM, while noting that email is a coordination and social engineering mechanism that may precede or coexist with the CPS-related actions on the control plane, rather than acting as a mechanism itself.

**Table 1.** Mapping of evaluated insider scenarios to smart-building operational analogues and observable evidence (BMS CPS slice).

| Scenario             | Smart-building analogue                                                                                                                                  | Impacted as-set/service                            | Primary evidence streams                                                                                  |
|----------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------|-----------------------------------------------------------------------------------------------------------|
| Exfiltration         | Bulk export of BMS configurations, floor plans, device inventories, or access-control schedules, potentially alongside procurement/HR records            | BMS repositories / facilities documentation stores | File access, large downloads, after-hours access, data-access patterns, email indicators                  |
| Stealth              | Small, incremental schedule/setpoint or alarm-threshold tweaks over days to mimic routine tuning and avoid spikes                                        | BMS configs / CPS telemetry (comfort/alarms)       | Low-amplitude deviations over time, repeated access patterns, configuration reads/writes, telemetry drift |
| Takeover             | Privilege escalation to facilities/BMS administrator followed by an unsafe schedule push, override, or alarm suppression                                 | BMS control plane (IAM + BMS)                      | Role/privilege changes, unusual admin actions, schedule/setpoint activation events, session anomalies     |
| Staging exfiltration | Staging compressed BMS backups or facility configuration bundles on shared drives/gateways prior to outbound transfer                                    | File servers / edge gateways / BMS backups         | Compression/archiving events, new staging directories, unusual storage growth, outbound attempts          |
| Email leakage        | Vendor spearphish or “official” work-order/change-request email used to obtain credentials/remote access or distribute malicious configuration artifacts | City email/collaboration + vendor ecosystem        | Authorship/style drift, abnormal recipients/domains, attachment anomalies, phishing likelihood signals    |

Our key contributions are as follows.

- We propose an adaptive insider threat detection framework for a smart building facilities setting that leverages multi-agent simulation (MAS), layered SIEM correlation, and cognitive/behavioral modeling. Our simulation models a realistic operational process where municipal staff and vendors interact with building systems, common resources, and communications.
- We propose a layered SIEM solution that improves detection capabilities through a stepwise process involving policy constraints, behavioral anomalies, and evidence-gated confirmation in a setting where operational noise is present.
- We incorporate Theory-of-Mind (ToM) intent signals and behavioral/communication forensics to provide context beyond raw logs. In particular, email is treated as an operational coordination and social-engineering channel (e.g., vendor change requests, work-order approvals, and phishing for remote access) that can be correlated with authentication anomalies and BMS control-plane actions.
- Empirical evaluations are carried out for four different variants of systems: LSC, CE-SIEM, EG-SIEM, and EG-SIEM-Enron. Several runs are made for different malicious behaviors. Improved actor-level detection is achieved with a reduction in false positives when compared to matched workload conditions.

The remainder of the paper is organized as follows: Section 2 reviews related work on insider-threat detection; Section III summarizes the dataset resources and preprocessing used to support email-style and phishing-related signals; Section IV presents our proposed hybrid framework; Section V describes the implementation and experimental evaluation, reporting results; finally, Section VI concludes with key findings and directions for future work.

## 2. Related Work

A prominent challenge in technology is the evolving landscape of cyber attacks and their catastrophic effects on various domains. Some of the persistent attacks include malware and ransomware, phishing, social engineering, among many more. The use of any of these in anticipation of corrupting a network can be part of the act of an individual with malicious intent. Insider threat is a common and major challenge in cybersecurity affecting companies, organizations, academia, and government agencies. It has been reported that insider threats account for a fourth of all cyberattacks experienced by U.S. organizations [1]. Statistics show about 53% of organizations and 42% of U.S. federal agencies encountered attacks of insider threats every year [2]. These types of threats are carried out by an authorized personal or employee within an organization, whom may be familiar with the structure, valued properties, and security layers of the organization [3]. Common threats include but are not limited to disclosure of classified information, theft of personal information, trade secrets/intellectual property theft, and IT system sabotage [4].

The use of unsupervised learning methods have been known to be useful for anomaly detection of insider threats. Le et al. [3] propose an anomaly detection approach using unsupervised learning for insider threat detection by employing four unsupervised machine learning methods with different working principles and through the exploration of various representations of data with temporal information. In their work, Le et al. apply Autoencoder and Isolation Forest models for insider threat detection and analyze their relationship with investigation budgets, and they further demonstrate that voting-based ensembles of anomaly detection methods can enhance detection performance and robustness. Another form of insider threat detection using machine learning has been employed by Manju et al. [5] for user behavior analysis. In their study, Manju et al. employ anomaly detection using Isolation Forest and one-class SVM. Their results indicate that the Isolation Forest achieved higher recall and precision scores (0.80 and 0.92, respectively) compared to the one-class SVM (0.75 and 0.80), suggesting that the one-class SVM may have failed to identify some true insider threats and that the Isolation Forest model more accurately detected positive instances. With the accuracy being the same for both models, 0.90, but the Isolation Forest providing a higher precision result, this demonstrates that the model can excel with a false-positive associated cost [5].

Multiagent systems approaches have been proposed for insider threat detection. To improve existing insider threat detection methods, agent-based models have been applied to monitor user activity for more effective threat identification. Ghulam et al. [6] propose an Agent-based User-Profiling model that monitors behavior of authorized users in an organization to avoid the risk. In their study, the profile of all insiders are built and maintained by the proposed model and the profile is dynamic, continuously updated while monitoring the behavior of an insider. Nikolov et al. [7] propose a multi-agent ranking framework for advanced persistent threat detection through the use of behavioral-analysis and pattern recognition. In their work, Nikolov et al. simulate various attacks and inject them into real-world log files to emulate typical network activity, including background traffic that occurs daily and that adversaries may exploit to conceal their actions. The results demonstrate that the with some exceptions, 100% of all attacks have been ranked in the top

20, indicating an analyst would need to analyze 20 entries to capture all possible attacks in these scenarios. Text mining enables cognitive profiling of email senders by extracting demographic (age range, gender) and thematic markers from linguistic patterns, creating behavioral fingerprints for anomaly detection [8]. This builds on extensive prior work in author attribution across linguistics, psychology, and NLP, where stylistic differences reliably signal identity and intent.

Newman et al. [9] analyzed 1400 text samples, finding women use more emotion/social relation words while men favor objective/impersonal vocabulary—key markers for gender profiling. Argamon et al. [10] achieved 80% gender classification accuracy (98% genre-specific) using n-grams and function words, combining stylometry with ML. Coyotl-Morales et al. [11] mined frequent word sequences (function + content) for 76.8% accuracy on poetic authorship.

Character-level language models proved robust for topic-neutral gender identification in scientific texts and blogs [12], though limited to eight lexical/syntactic features. Shrestha et al. [13] profiled 85,000 health forum users, achieving 61–65% age prediction across 3–5 ranges using word/character n-grams, familial terms, and forum-specific cues.

Prior works do not treat multi-agent systems and anomaly-based machine learning as a unified model. In contrast, we propose a hybrid framework that integrates agent-based reasoning, behavioral analytics, and adaptive learning. Adaptive learning improves existing threat detection capabilities, both in classical machine learning approaches and in proposed multi-agent detection systems, by adjusting to the evolving behaviors of malicious actors, which change gradually and strategically. The integration of a multi-layered SIEM architecture enables trust-adaptive thresholds and continuous online model updates, resulting in more resilient and context-aware detection performance.

Our email forensics pipeline extends this lineage by fusing content-based NLP (tokenization, NER, phishing detection) with authorship profiling (gender/age/topic markers) and AI-synthetic text probability, producing unified cognitive vectors for SIEM integration. Unlike prior isolated classifiers, we correlate these profiles with behavioral anomalies and ToM intent signals, enabling nuanced insider detection via stylistic deviations from established sender baselines.

### 3. Dataset Description

We utilize the Enron email dataset [14], which comprises approximately 500,000 messages from 150 employees of the Enron Corporation. After data pre-processing with the removal of very short emails and the parsing of the raw text of the email bodies, we were left with 422,204 emails. From these, we calculate global reference statistics such as the average sentence length and the lexical density necessary for the construction of profiles for the respective sender email addresses that have enough email communications (five minimum).

The Enron Spam Dataset [15] contains 33,716 labeled emails (51% spam, 49% ham) curated from the original Enron corpus for spam filtering benchmarks. It includes columns for Subject, Message body, Spam/Ham labels, and Date, making it suitable for NLP-based behavioral forensics in insider threat detection. Preprocessing involves filtering messages over 30 words, a stratified hold-out split (85% training, 15% testing), and augmentation with synthetic MAS outputs for enterprise email pattern analysis. Additionally, we employed various text generation libraries to create 3,500 synthetic emails depicting suspicious activities such as malicious attachments, invoices, spoofing, critical security alerts, phishing, fake surveys, and fraudulent information requests.

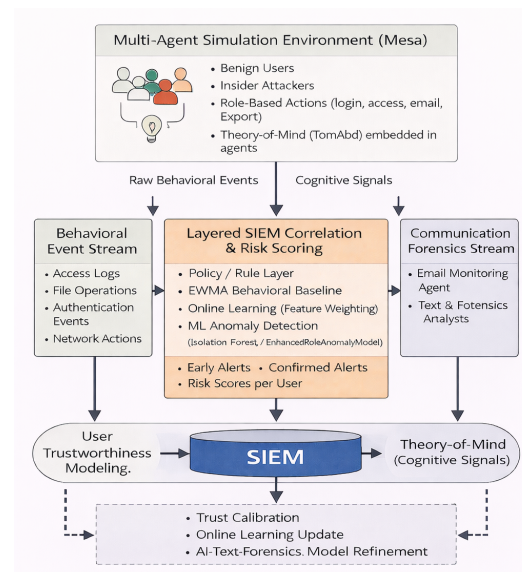


## 4. Proposed Methodology

Our framework combines multi-agent simulation, layered correlation from SIEM, communication forensics, and cognitive trust with Theory-of-Mind (ToM) reasoning into an insider threat detection framework. As shown in Figure 1, a municipal smart-building facilities simulation running Mesa generates behavioral events and intent predictions for legitimate users as well as insider attackers. Both sets of data, along with data from an intersecting communication forensics component, are fed into a centralized layered SIEM correlation and risk scoring component. The SIEM component becomes the centralized authority for both early and confirmed alerts and captures data for determining the trustworthiness of all users and model calibration feedback for improving detection performance with time. We proceed with the detailed discussion of the different components of our framework.

### 4.1. Multi-Agent Simulation (MAS)

We construct a municipal smart-building facilities environment in Mesa [16] where agents represent users and insider attackers. Agents have roles (staff, developer, admin) and resources they can access. A subset of agents are adversaries executing insider tactics e.g. data exfiltration, privilege escalation, colluding with external parties. The simulation runs in discrete timesteps; at each step, agents perform actions such as login, database queries, file exports, or sending emails. Crucially, each agent is embedded in a Theory-of-Mind (ToM) layer implemented via TomAbd[17] which is an abductive Theory-of-Mind framework that infers latent agent beliefs, goals, and plans from observed actions. Unlike purely statistical anomaly detection, TomAbd enables plan-aware and intention-driven reasoning under partial observability, making it particularly suitable for insider threat scenarios where malicious behavior unfolds gradually and strategically. TomAbd maintains beliefs, goals, and nested plans for each agent. Observed actions feed into an abductive reasoning module that infers intentions e.g. “this user likely aims to exfiltrate BMS configuration backups or access-control schedules”. These inferred intentions are available as meta-features to the SIEM. In this way, the simulator produces not only raw event logs but also cognitive/contextual signals about each agent’s state and predictions of next steps. The MAS can scale from dozens to thousands of agents, supporting a wide range of diverse scenarios. We use Mesa [16] for flexibility and integration with our SIEM code.



**Figure 1.** Overview of the Proposed Hybrid Insider Threat Detection Framework

#### 4.2. SIEM Layering

All events from the MAS flow into a central SIEM component. This SIEM correlates data and issues alerts through multiple configurable layers:

- **Policy layer:** This involves static policies or rules regarding violations such as the absence of access to certain servers or against the sharing of files, and this layer functions as a coarse filter, suppressing or marking certain actions, such as sending BMS configs/floor plans to external email.
- **Baseline anomaly layer:** This involves the use of the Exponentially Weighted Moving Average (EWMA) model to observe the usual rates for each user's activity, for example, log-in rates and data downloaded. Any deviation from the usual rates translates to a baseline score. A good example of this is when an employee who has not been actively accessing any data downloads heavily.
- **Trust-adaptive threshold:** One of the major contributions of the approach is that there is a user-specific, adaptively set warning threshold that is a function of the user's "trust score." More concretely, the approach utilizes both an "early warning" threshold and a "confirmed" threshold. The confirmed threshold is calculated using  $\text{base} + \text{slope}(\text{trust} - 0.5)$ . The trust scores begin at 0.7 and evolve over time. A more trustworthy individual requires a stronger cumulative score for an alert to sound, while a less trustworthy individual needs a weaker score. This adds the notion that the record of previous alerts, true or false, impacts current alert sensitivity.
- **Online learning layer:** In this layer, a logistic regression model is maintained using handcrafted features such as anchors "recent email," "after-hours login," and "large export". In this layer, a warm-up phase is used where a benign dataset is learned by a logistic regression model, and then the model is further honed using rankings provided by analysts (simulated truth) for online learning and weighing of parameters.
- **Isolation Forest anomaly detection:** Finally, for each user-role, we train an Isolation Forest on historical behavior vectors and score new activity. Outlier scores from the forest nudge borderline cases; by default we weight the ML anomaly as a "weak advice" that can raise a score that is near the threshold.

The SIEM maintains a sliding window of recent activity for every unique user. At every anchor point (e.g. an email or login entry point), it computes the baseline score based on weighted features, then combines this with the baseline anomaly score, and finally compares it to early and confirmed thresholds, respectively. Alerts are raised in tiers (e.g. a low-confidence early alert vs a high-confidence confirmed alert). All alerts are timestamped and labeled with user ID and context for evaluation.

In addition to basic correlation and risk scoring, we incorporate mechanisms to minimize the problem of false positives and increase the confidence of the analyst. First, regularity of behavior as a regular pattern is captured by measuring deviations from expected inter-arrival patterns and suppressing risk scores if behavior follows regular patterns. Second, peer group normalization is incorporated by comparing the export behavior of a given user to those with a similar role and scoring only those users who are significant outliers relative to their peer group. Third, for confirmed alerts, evidence accumulation is a requirement: at least two distinct types of evidence must be present before escalation occurs. Confirmed escalation involves a multi-condition gate such as Tight Exfiltration Chains, Staging Activity, Login Context, or Excess Evidence. Lastly, a compliance override is incorporated to ignore alerts indicating confirmed escalation in the presence of strong compliance factors.

The effectiveness of the system is evaluated by means of a measurable set of five insider threat scenarios that include exfiltration, stealth, takeover, staging exfiltration, and

email leakage, in addition to providing metrics from the actor and alarm views. These metrics include precision, recall, F1, and Time-To-Detection (TTD).

#### 4.3. Behavior and Prompt Forensics.

Parallel to raw event analysis, the system deploys specialized forensics agents to process communication content. In the case of email traffic, an Email Monitoring Agent analyzes both the raw text and associated metadata of each incoming message. As illustrated in Figure 2, the email is evaluated through two complementary analysis streams operating in parallel.

The first stream carries out the content-based natural language processing (NLP) analysis by applying text-mining methodologies like tokenization, named entity identification, indicator identification, and phishing/spam categorization in accordance with the text-mining data sources utilized by the SIEM solution. The first stream identifies the semantic and functional aspects associated with the email content.

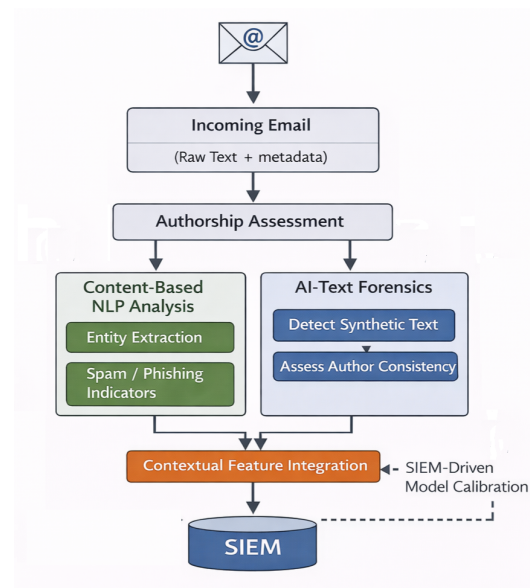
At the same time, an AI text forensics stream deals with authorship and text generation features. This assessment calculates the probability of an email being generated or supported by AI and assesses the uniformity of style with respect to past writing patterns. Instead of aiming to determine specific attribution, the forensic tool provides probabilities regarding the usage of synthetic text and style consistencies regarding the author, which serve as behavioral cues.

The results of these two streams of analyses are then fused by means of a contextual feature integration layer to produce a unified feature vector that embraces content-level markers and signals associated with authorship. This augmented metadata serves to inform the SIEM system about correlations with behavioral activity markers, usage patterns, and role-defined expectations. Thus, it becomes clear that the SIEM risk score processing would be based on email transmission activity, along with markers associated with composition and possible authorship (AI-based).

We extend the Email Monitoring Agent by introducing the pretrained forensics component, which is loaded dynamically as a serialized resource at runtime. This component is trained to operate on two differing Enron datasets: (1) the full Enron email dataset, used to establish baselines on writing styles and vocab statistics, and (2) the Enron Spam Dataset, used to train the phishing classifier component. On every outgoing email event, the component calculates: (i) phishing probability via supervised classification trained on the Enron spam/ham dataset enhanced by keyword features; (ii) urgency indicators for sensitive keywords; (iii) writing style anomaly scores according to variance in Enron baselined stats (sentence length & lexical diversity); (iv) authorship consistency using a rolling per-actor style profile; and (v) an AI likeness indicator derived via low variance in sentence length patterns scored per sentence. These feature values are then added to the email event and aggregated over some time period. The SIEM scoring and correlation component enables a forensics flag when the recent phishing probability of the actor crosses some threshold value, using this flag as weighted evidence in alert scoring & correlation logic. Enron datasets are used only to train/calibrate the pretrained forensics module; all emails in the MAS simulation are synthetically generated at runtime and are not drawn from Enron.

Moreover, the SIEM also provides a feedback mechanism based on alert outcomes and validation by the human analyst (for example, confirmation or flagging it as a false positive). This feedback can be used to refine the models of AI-text forensics and classification to enable improved detection rates without affecting real-time email processing.





**Figure 2.** Email Monitoring Agent's Text Mining and Prompt Forensics Pipeline

#### 4.4. Theory-of-Mind and Trust Modeling

In the MAS, agents hold a user trustworthiness score that is controlled by the SIEM, indicating the confidence of the system in the benign nature of the user. This score changes depending on the results and confirmation of alerts. If the alert is a true positive, indicating malicious or policy-breaking activity, the user's score will go down, and subsequent actions will be stringently reviewed. However, in the case of a false positive, the score increases, and subsequent actions will have less severe reviews. Concretely, on a malicious hit we apply a fixed negative delta to trust; on a false alarm, we add a positive delta. Trust is bounded between 0.10 and 0.95. Over time, trust gradually decays toward the baseline. This models an adaptive "confidence" in each user's benignness, which then influences the alerting threshold as described. By dynamically calibrating trust, we mimic human-AI collaboration: analysts learn to trust the system for users that turn out benign, and demand more evidence for repeat offenders.

In tandem, the ToM layer in each agent continuously infers others' intentions. For example, observing an agent performing an unusual query may lead TomAbd to infer a goal of data theft. These inferences enter the SIEM as a kind of "cognitive clue". While our current SIEM score is primarily feature-driven, we plan to integrate these ToM signals into future alert models, allowing intent reasoning to flag coordinated or subtle attacks.

#### 4.5. Enhanced Anomaly Model

Beyond the base system, we introduce an EnhancedRoleAnomalyModel to improve ML detection. This model extends the basic isolation forest by using richer temporal features e.g. burst patterns, time-of-day ratios, velocity of actions and by maintaining separate models per role and behavior pattern. It also carefully excludes known adversarially-controlled users from training to avoid taint. In essence, it produces a more discriminative anomaly score for each user-role context. While our experiments focus on the baseline isolation forest, this enhanced model is a key planned upgrade to boost accuracy.

In summary, our methodology follows the unified framework where MAS simulates insider interactions, behavioral forensics analyzes human/AI-generated content, and dynamic trust models tailor alerts to human analysts. The SIEM layers operationalize this by correlating everything in real time, and the ML and ToM components enable adaptive, intention-aware threat detection.

**Table 2.** Enron-calibrated email forensics module: baseline statistics and phishing classifier performance.

| Item                                    | Value   |
|-----------------------------------------|---------|
| Full Enron emails (after preprocessing) | 422,204 |
| Vocabulary size (baseline)              | 575,895 |
| Baseline sentence length                | 14.60   |
| Baseline lexical richness               | 0.633   |
| Spam/ham samples (after filtering)      | 33,218  |
| Feature dimension (TF-IDF)              | 8,000   |
| Logistic Regression test accuracy       | 0.9988  |
| Naive Bayes test accuracy               | 0.9894  |
| Random Forest test accuracy (selected)  | 0.9998  |
| Test set size (spam+ham)                | 4,983   |

## 5. Implementation and Results

To analyze the impact of cognitive context and precision-focused gating, four variants of the proposed framework are evaluated. Layered SIEM-Core (LSC) serves as the baseline framework that represents a traditional layered SIEM processing pipeline consisting of policy verification, trust-aware scoring, EWMA based deviation modeling, as well as deviation detection based on fixed confirmation thresholds, all of which do not make use of cognitive processing or communication evidence. Based on this starting point, Cognitive-Enriched SIEM (CE-SIEM) enhances the correlation layer with the incorporation of Theory-of-Mind (TomAbd)-based intent features and communication forensics features such as natural language processing for phishing purposes and AI text/authorship analysis. This is combined with behavioral anomalies with the same confirmation logic as the original approach. Next, Evidence-Gated SIEM (EG-SIEM) introduces precision-focused validation layers upon CE-SIEM. The variation imposes the use of evidence-gated accumulation, the use of peer-group normalization compared to role-based behavioral groups, the exclusion of routine and scheduled events, and the inclusion of Theory-of-Mind validation with awareness of contradiction. The various validation methods are expected to optimize the prevention of false positives and the number of alerts, with quick detection being ensured. Lastly, the Enron-enabled EG-SIEM (EG-SIEM-Enron) builds upon the EG-SIEM framework, dynamically loading the pretrained Enron-centric email forensics module during runtime. This component contributes normalized estimates of phishing likelihood and style-baseline deviation, all of which are combined into weighted evidence within alert scores and correlation. The proposed validation and calibration techniques are expected to reduce false positives and alert rates while preserving timely detection. The pretrained email forensics module is trained offline using two Enron-derived resources: the full Enron corpus to estimate global style baselines and sender-profile statistics, and the Enron spam/ham dataset to train a phishing classifier. Using a stratified hold-out split (85% training, 15% testing), we evaluate several classifiers on TF-IDF features (8,000 terms) and select Random Forest based on test accuracy (0.9998). Table 2 summarizes baseline statistics and classifier performance used by EG-SIEM-Enron at runtime.

The above variants are implemented using Python Mesa to simulate the multi-agent system and incorporating customized modules for SIEM, TomAbd, and Behavioral Forensic; the implementation and experiment scripts are publicly available for reproducibility [18]. The simulation models a municipal smart-building facilities environment with 42 human agents: 30 benign municipal users, 4 power users, and 8 malicious insiders across five attack scenarios, plus 4 system agents (DBMonitor, EmailMonitor, AuthMonitor, and SIEMAgent), for 46 total agents in the Mesa model. In addition to regular benign users, we model a small number of power users with privileged access consistent with facilities operations, such as

BMS operators, facilities engineers, and vendor-integrator accounts. Power users exhibit a higher baseline rate of legitimate file access, database queries, configuration reads/writes, and data exports than regular users; this role supports stress-testing baseline models and peer-group normalization. In each run, a total of  $T = 240$  simulation steps are executed, with an initial 60-step warm-up period for developing baselines and building anomaly models based on roles. Post-warm-up, the testing phase begins with insider activities enabled. In each run, the SIEM system ingests monitored events and produces two levels of alerts: Early Alerts for Triage and Confirmed Alerts for Escalation.

Ground-truth labels are generated directly by the simulator based on the assigned role and actions of actors. Evaluated metrics are: (i) actor precision, recall, and F1, considering an actor to be detected whenever they generate at least one confirmed alarm in the testing phase, (ii) alert precision regarding early and confirmed alarms, and (iii) time to detection, calculated from the first malicious activity to the first confirmed alarm.

### 5.1. Quantitative Results and Trade-offs

Table 3 summarizes the averaged performance over 10 runs for the four configurations. For the LSC baseline, we report the operating point with confirmed threshold  $\theta = 4$ , which yields a confirmed-alert volume (69.7/run) comparable to EG-SIEM (71.5/run) and EG-SIEM-Enron (73.4/run), enabling a workload-matched comparison. Baseline (LSC) at  $\theta = 4$ , LSC achieves actor-level  $F1=0.521$  ( $P=0.369$ ,  $R=0.888$ ) with confirmed-alert precision 0.543. Although recall remains relatively high, the baseline generates substantial false positives (31.6 confirmed FP/run) at this alert volume, reflecting limited discrimination when cognitive and communication-derived evidence is unavailable.

Adding Theory-of-Mind and communication forensics in CE-SIEM increases actor-level performance to  $F1=0.774$  ( $P=0.633$ ,  $R=1.000$ ), representing a large gain over LSC (Fig. 3). This improvement is achieved by detecting all insider actors ( $R=1.0$ ) but comes with a higher operational burden: CE-SIEM produces 152.0 confirmed alerts per run and confirmed-alert precision of 0.677, indicating a stronger but noisier detection posture.

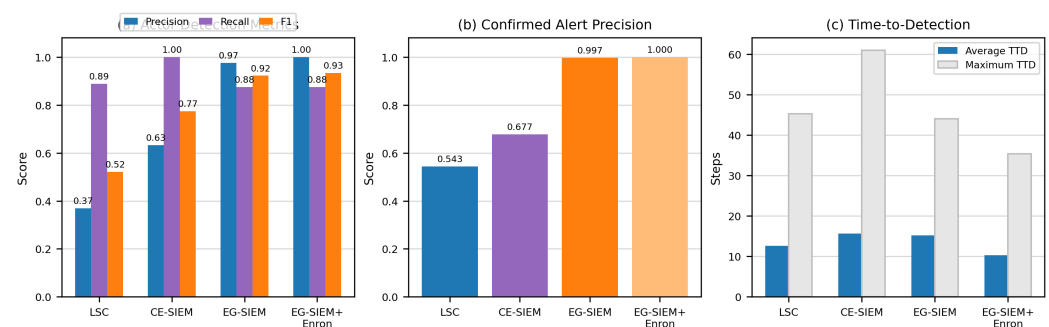
EG-SIEM substantially improves reliability and reduces alert fatigue. Actor-level F1 rises to 0.922 ( $P=0.975$ ,  $R=0.875$ ) while confirmed-alert precision reaches 0.997 with only 71.5 confirmed alerts per run and 0.2 confirmed FP/run. Compared to CE-SIEM, EG-SIEM cuts confirmed alert volume by  $\approx 53\%$  while improving confirmed-alert precision from 0.677 to 0.997. The trade-off is a modest reduction in recall (7/8 insiders detected on average), consistent with stricter confirmation criteria. Average time-to-detection (TTD) remains comparable for CE-SIEM and EG-SIEM (15.68 vs. 15.20 steps), while EG-SIEM improves worst-case TTD (max 44 vs. 61), indicating more consistent detection under stochastic behavior.

Finally, EG-SIEM-Enron enhances EG-SIEM by adding a trained email forensics module based on the Enron corpus. This provides a phishing likelihood measure as well as a measure of deviation from the email style baselines to be used as additional weighted evidence. The parameters keep a conservative alert policy (0.0 confirmed FP/run; confirmed-alert prec. 1.000) but offer a small increment to actor-level F1 to 0.933 ( $P=1.000$ ,  $R=0.875$ ). Crucially, EG-SIEM-Enron also reduces the average TTD to 10.26 steps (previously 15.20 steps), with max TTD also reduced from 44.0 to 35.4 steps. This indicates that the added communication calibration improves the timeliness of high-confidence detections without increasing false alarms.

Figure 4 presents the LSC baseline performance across different confirmation thresholds ( $\theta = 3$  to 7). The analysis reveals the inherent precision-recall trade-off in traditional SIEM approaches. As shown in Figure 4, increasing the confirmation threshold improves precision (from 0.345 at  $\theta=3$  to 0.462 at  $\theta=7$ ) but degrades recall (from 0.913 to 0.750) and

**Table 3.** Actor-level detection and alert statistics across SIEM variants (10 runs, 240 steps/run, 60-step warmup).

| Metric                        | LSC   | CE-SIEM | EG-SIEM | EG-SIEM-Enron |
|-------------------------------|-------|---------|---------|---------------|
| Actor Precision               | 0.369 | 0.633   | 0.975   | 1.000         |
| Actor Recall                  | 0.888 | 1.000   | 0.875   | 0.875         |
| Actor F1                      | 0.521 | 0.774   | 0.922   | 0.933         |
| TTD avg (steps)               | 12.58 | 15.68   | 15.20   | 10.26         |
| TTD max (steps)               | 45.3  | 61.0    | 44.0    | 35.4          |
| Confirmed alerts (avg/run)    | 69.7  | 152.0   | 71.5    | 73.4          |
| Confirmed-alert precision     | 0.543 | 0.677   | 0.997   | 1.000         |
| Confirmed FP (avg/run)        | 31.6  | 49.1    | 0.2     | 0.0           |
| ToM-assisted detections (avg) | –     | 111.2   | 31.9    | 31.8          |

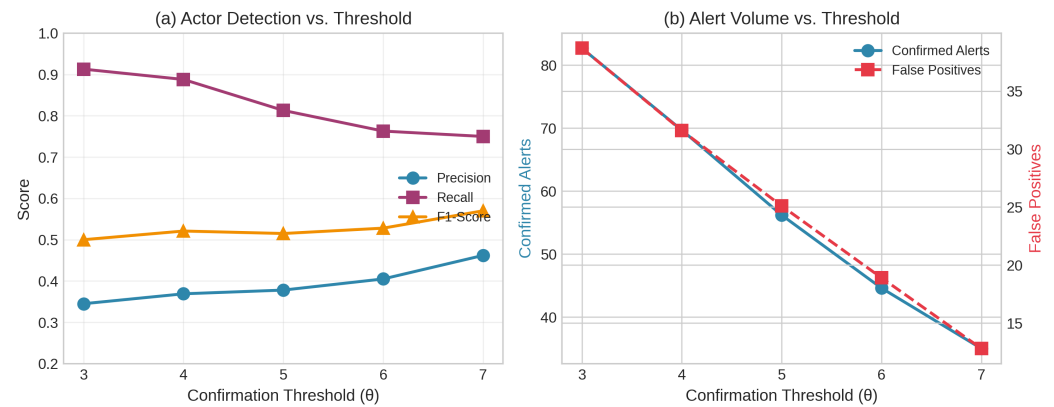
**Figure 3.** Actor-level precision, recall, and F1 (10-run averages) for LSC, CE-SIEM, EG-SIEM, and EG-SIEM-Enron.

increases detection latency (average TTD rises from 13.09 to 39.13 steps). This trade-off demonstrates the fundamental limitation of threshold-based approaches: without cognitive context or evidence gating, the system cannot simultaneously achieve high precision and rapid detection.

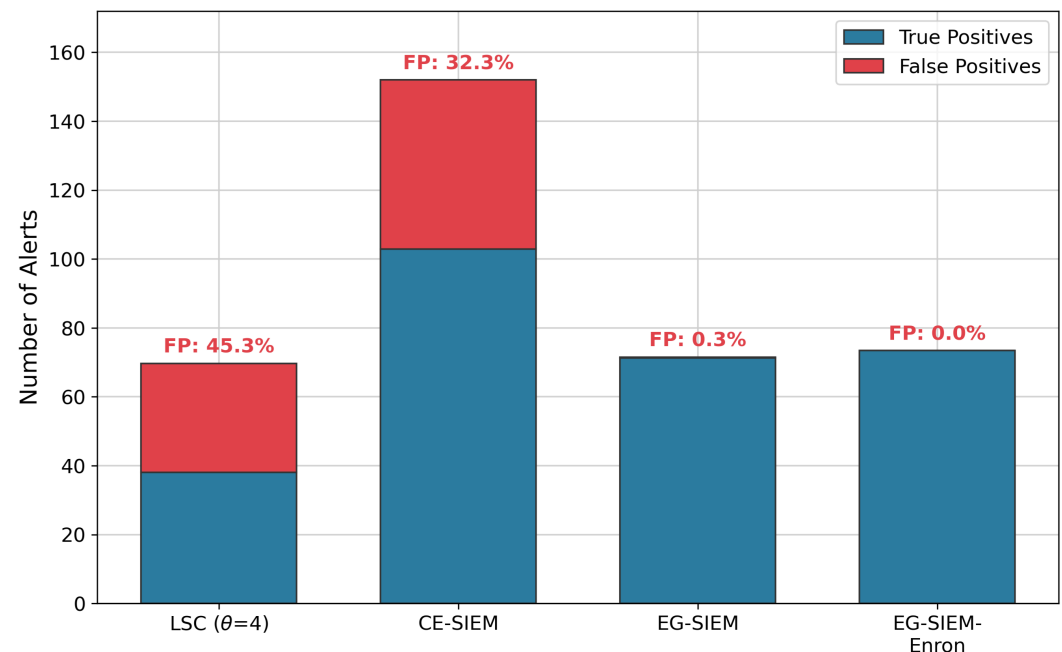
The addition of Theory-of-Mind (TomAbd) features and behavioral forensics in CE-SIEM substantially improves detection capability. The system achieves perfect recall (1.000), successfully detecting all 8 malicious insiders across all simulation runs. The TomAbd module contributed an average of 111.2 assisted detections per run, demonstrating the value of intent inference and belief modeling in identifying suspicious behavioral patterns that evade traditional rule-based detection. However, the cognitive enhancement comes with increased alert volume (152.0 confirmed alerts vs. 69.7 for LSC ( $\theta = 4$ )), indicating that while detection sensitivity improves, the system requires additional filtering mechanisms to maintain operational efficiency.

EG-SIEM introduces precision-focused validation layers that dramatically reduce false positives while maintaining high detection rates. The evidence-gated approach demonstrates remarkable consistency: 8 out of 10 runs achieved perfect precision (1.000) with zero false positives. Only runs 7 and 8 produced a single false positive each, resulting in an average of just 0.2 false positives across all runs. The consistent recall of 0.875 (detecting 7 out of 8 malicious actors) indicates that the precision gains do not come at the cost of missing true threats. EG-SIEM-Enron further eliminates false positives in our runs (0.0 confirmed FP/run) while maintaining the same actor recall (0.875) and improving time-to-detection.

Figure 5 presents the alert composition analysis showing true positives versus false positives. EG-SIEM achieves 99.7% alert precision with minimal false alarms, while EG-SIEM-Enron achieves 100% alert precision with zero false alarms.



**Figure 4.** LSC sensitivity to confirmed threshold  $\theta$  (10-run averages)



**Figure 5.** Alert composition analysis showing true positives versus false positives

## 6. Conclusion

In this work, a hybrid framework for insider threat detection that incorporates multi-agent simulation, Trust-Aware learning, Behavioral and communication forensics, and Theory-of-Mind (TomAbd) Reasoning is described, and experiments conducted on four different implementations attested to a progressive improvement in detection ability and practicability. The Layered SIEM-Core (LSC) approach highlights that simply applying constant thresholds has clear disadvantages, implying a very high number of false positives for meaningful workloads. The combination of cognitive and communication-domain evidence in CE-SIEM can significantly boost detection ability, improving F1-measures for actors from 0.521 (LSC) to 0.774 while maintaining absolute recall (1.000) for all insiders, but at a cost in alert volume. The EG-SIEM approach largely overcame this tradeoff by adding evidence accumulation, peer group normalization, regularity suppression, contradiction sensitive ToM reasoning, implying superior actor detection ability ( $F1 = 0.922$ ) and very close to perfect alert precision (0.997) while incurring a very low FP rate (0.2 alerts) in a very short time frame. Finally, EG-SIEM-Enron further strengthens the operational posture by eliminating false positives (0.0/run), slightly improving F1 (0.933), and reducing detection latency (average TTD 10.26 steps), suggesting that pretrained email forensics can accelerate



high-confidence detection without increasing noise. Overall, the results emphasize a simple lesson: context improves sensitivity, but disciplined evidence validation is what makes detection practical.

Future work will incorporate Theory of Mind (ToM) inputs more directly into the SIEM scoring and learning systems and test the framework on a bigger scale with more varied and coordinated insider actions and compare the performance of the EnhancedRoleAnomalyModel against the current method used by the existing anomaly detection algorithm. We will also study federated and privacy-preserving machine learning and human-in-the-loop experiments regarding analyst workload and trust and the quality of triage in a real security operation center (SOC) context.

## References

1. CSO.; of SEI-CMU, C.D.; Service, U.S.; KnowBe4. The 2018 U.S. State of Cybercrime Survey. Technical report, Int. Data Group, Boston, MA, USA, 2018. Accessed: Apr. 1, 2021.
2. Partners, C.R. 2018 Insider Threat Report. Technical report, CA Technologies, New York, NY, USA, 2018. Accessed: Apr. 1, 2021. [Online].
3. Le, D.C.; Zincir-Heywood, N. Anomaly detection for insider threats using unsupervised ensembles. *IEEE Transactions on Network and Service Management* **2021**, *18*, 1152–1164.
4. Collins, M.L.; Theis, M.C.; Trzeciak, R.F.; Strozer, J.R.; Clark, J.W.; Costa, D.L.; Cassidy, T.; Albrethsen, M.J.; Moore, A.P. Common Sense Guide to Mitigating Insider Threats, Fifth Edition. Technical Report CMU/SEI-2015-TR-010, CERT Insider Threat Center, Software Engineering Institute, Carnegie Mellon University, Pittsburgh, PA, USA, 2016.
5. Manju, A.; Puteh, M.; Subha, R. Insider Threat Detection using Machine Learning Models for User Behavior Analysis. In Proceedings of the 2025 5th International Conference on Expert Clouds and Applications (ICOECA). IEEE, 2025, pp. 811–814.
6. Ali, G.; Shaikh, N.A.; Shaikh, Z.A. Towards an automated multiagent system to monitor user activities against insider threat. In Proceedings of the 2008 International Symposium on Biometrics and Security Technologies. IEEE, 2008, pp. 1–5.
7. Nikolov, G.; Debatty, T.; Mees, W. Evaluation of a multi-agent anomaly-based advanced persistent threat detection framework. In Proceedings of the The Twelfth International Conference on Evolving Internet (INTERNET 2020), 2020.
8. Kurdi, M.Z. Content-Dependent Versus Content-Independent Features for Gender and Age Range Identification in Different Types of Texts. In Proceedings of the Proceedings of the 32nd International Florida Artificial Intelligence Research Society Conference (FLAIRS-32), Sarasota, FL, United States, May 19–22 2019; pp. 183–188. <https://doi.org/10.5555/370>.
9. Newman, M.L.; Groom, C.J.; Handelman, L.D.; Pennebaker, J.W. Gender differences in language use: An analysis of 14,000 text samples. *Discourse Processes* **2008**.
10. Argamon, S.; Koppel, M.; Fine, J.; Shimon, A.R. Gender, genre, and writing style in computer mediated communication. *Proceedings of the 28th Annual Conference of the Cognitive Science Society* **2003**.
11. Coyotl-Morales, R.M.; Villaseñor-Pineda, L.; Montes-y Gómez, M.; Rosso, P. Authorship Attribution Using Word Sequences. In Proceedings of the Progress in Pattern Recognition, Image Analysis and Applications, 11th Iberoamerican Congress on Pattern Recognition, CIARP 2006, Cancún, Mexico, November 14–17, 2006, Proceedings. Springer, 2006, pp. 844–853. [https://doi.org/10.1007/11892755\\_87](https://doi.org/10.1007/11892755_87).
12. Sarawgi, R.; Gajulapalli, K.; Choi, Y. Gender Attribution: Tracing Stylometric Evidence Beyond Topic and Genre. In Proceedings of the Proceedings of the Fifteenth Conference on Computational Natural Language Learning, Portland, Oregon, June 23–24 2011; pp. 78–86.
13. Shrestha, P.; Bethard, S.; Pedersen, T.; Rey-Villamizar, N.; Farig, S.; Solorio, T. Age and Gender Prediction on Health Forum Data. In Proceedings of the Proceedings of the Tenth International Conference on Language Resources and Evaluation (LREC 2016), Portorož, Slovenia, May 23–28 2016; pp. 69–74.
14. Cukierski, W. The Enron Email Dataset, 2015.
15. Wiechmann, M. Enron Spam Data, 2021.

16. ter Hoeven, E.; Kwakkel, J.; Hess, V.; Pike, T.; Wang, B.; rht.; Kazil, J. Mesa 3: Agent-based modeling with Python in 2025. *Journal of Open Source Software* **2025**, *10*, 7668. <https://doi.org/10.21105/joss.07668>.
17. Montes, N.; Luck, M.; Osman, N.; Rodrigues, O.; Sierra, C. Combining Theory of Mind and Abductive Reasoning in Agent-Oriented Programming. In Proceedings of the Proceedings of the 23rd International Conference on Autonomous Agents and Multiagent Systems, Richland, SC, 2024; AAMAS '24, p. 2839–2841.
18. Kausar, F. Insider-Threat-Detection-MAS-SIEM. <https://github.com/firdous3679/Insider-Threat-Detection-MAS-SIEM>. Accessed: 2025-12-30.

**Disclaimer/Publisher's Note:** The statements, opinions and data contained in all publications are solely those of the individual author(s) and contributor(s) and not of MDPI and/or the editor(s). MDPI and/or the editor(s) disclaim responsibility for any injury to people or property resulting from any ideas, methods, instructions or products referred to in the content.